

RiskWaiver360

GRC Process Exception &
Policy Waiver Management Platform

TEAM: S Abhilash · Rajath S

INSTITUTION: RVCE (RV College of Engineering), Bengaluru

TRACK: Policy Governance & Risk Management

YEAR: 2026 · Societe Generale Hackathon



GRC

Where Do Policy Exceptions Live Today?

- Scattered across email threads and Slack messages
- Tracked informally in spreadsheets with no lifecycle control
- Expired exceptions left active — never revoked
- No central visibility for security teams or auditors
- Access granted "temporarily" becomes permanent without review
- Hidden attack paths grow where exceptions are forgotten

Audit Risk

No evidence trail for expired exceptions

Security Gaps

Expired firewall & access exceptions still active

Compliance Drift

Policies waived without proper justification

01

Orphaned Access

User left the org — access exception never revoked. Account remains open.

02

Overlapping Waivers

Two exceptions approved for the same asset and policy. No one noticed.

03

Conflicting Approvals

One approver approved; another rejected. System shows both records.

04

Long-Running Temp Access

"Temporary" admin access from 18 months ago — still active, never reviewed.

05

Risk Accumulation

15 exceptions on one critical asset. Combined exposure is extremely high.

06

Audit Failure

Auditor requests evidence. No justification, no review record, no expiry trail.

CENTRALIZED

Single source of truth for all exceptions

RISK-SCORED

Quantitative scoring, not guesswork

LIFECYCLE-TRACKED

From intake to expiry, every step recorded

AUDIT-READY

Evidence-backed, exportable reports

Exception Lifecycle Flow

1

Structured
Intake

2

Security
Review

3

Approver
Decision

4

Continuous
Monitoring

5

Audit
Evidence

"Turn scattered exceptions into governed, scored, lifecycle-tracked decisions."

PRESENTATION LAYER

- › React 18 + Vite · Role-Based Workspaces
- › 4 Role Views: Requester / Reviewer / Approver / Auditor

API LAYER

- › Node.js + Express REST API · Port 4000
- › Routes: Exceptions · Approvals · Alerts · Conflicts · Audit

DATA & SERVICES LAYER

- › JSON Flat-File Storage (Demo) · 600 Exception Records
- › Services: Risk Scoring · Alert Engine · GRC Intelligence · Audit

Engines:

Risk Scoring

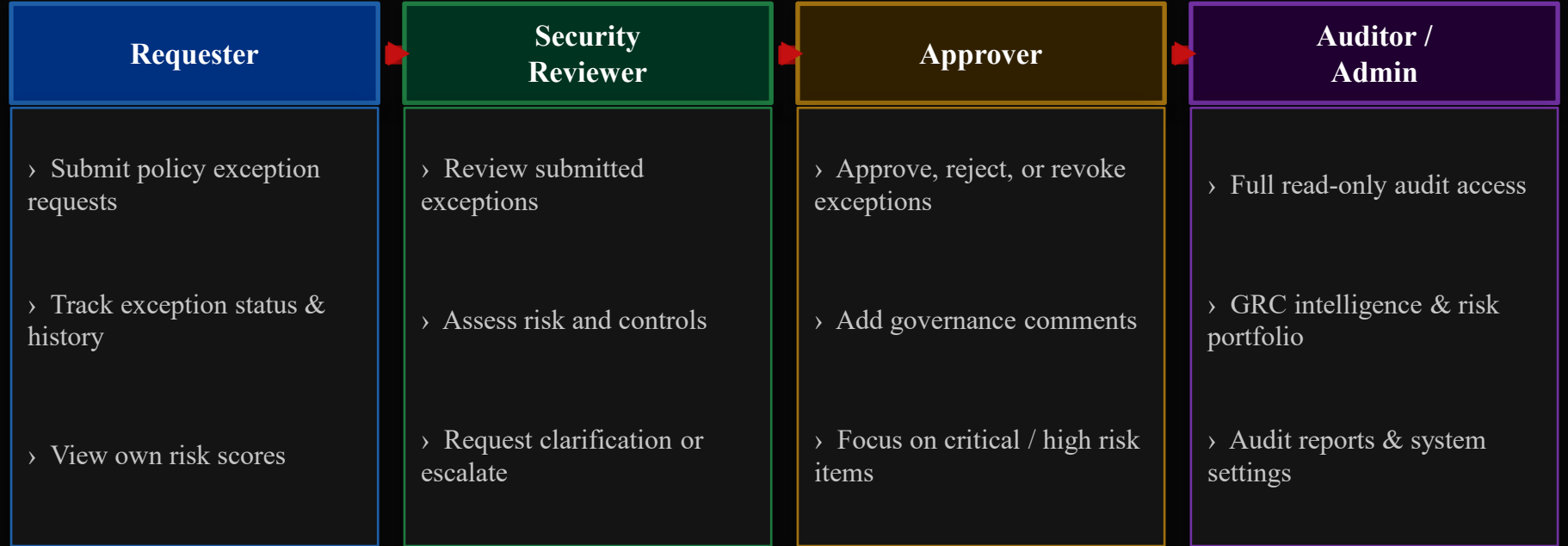
Alert Engine

GRC Intelligence

Audit Report

Role-Based Workflow — Four Workspaces

6/12



Exception Status Flow:



Every action is timestamped and stored in the exception history for audit evidence.

01 Exception Risk Register

Filterable registry of all 600 exceptions. Search, filter by dept, status, risk, type.

02 Structured GRC Intake

Validated intake form: exception type, asset, policy, CIA, owner, justification.

03 Security Review Queue

Prioritized queue for reviewers. Checklist, risk bands, action buttons.

04 Exception Evidence File

Full exception detail: lifecycle, approvals, history, GRC conflicts, risk score.

05 Risk Scoring Engine

Rule-based score (0-100). Type + Asset + Duration + Expiry + Review - Controls.

06 Continuous Monitoring

682 alerts: overdue, expiring soon, orphaned owner, missing controls, review due.

07 GRC Intelligence Center

Detects overlaps (90), duplicates (59), conflicts, and risk accumulation hotspots (37).

08 Audit-Ready Reports

Department & risk breakdown, lifecycle analysis, printable evidence packs.

09 Settings & Roadmap

Dataset stats, scoring config, role matrix, limitations, and production roadmap.

$$\text{Risk Score} = \text{Type Weight} + \text{Asset Criticality} + \text{Duration Penalty} + \text{Expiry Status} + \text{Review Penalty} + \text{Owner Status} - \text{Control Bonus}$$

Scoring Factors

Exception Type	20 – 35 pts	Admin Access 30, Firewall 25, Encryption 35...	Review State	0 – 10 pts	Never reviewed: +10, Overdue: +5
Asset Criticality	10 – 30 pts	Critical asset adds 30 pts	Owner Status	0 – 10 pts	Inactive / unassigned owner: +10
Duration Penalty	0 – 15 pts	>90 days: +10, >180 days: +15	Control Bonus	0 – 15 pts	Strong compensating control: -15
Expiry Status	0 – 20 pts	Overdue: +20, Expiring soon: +10			
Low 0–30			Medium 31–59		
			High 60–79		
			Critical 80–100		

Score Range 0–100 · Rule-based · Explainable · Audit-friendly

Continuous Monitoring Alerts

682 Total Active Alerts

Across all monitored exceptions

333 Critical Risk

Risk score ≥ 80 — immediate attention

156 Overdue Exceptions

Past expiry date, still active

127 Review Overdue

Not reviewed in 90+ days

24 Missing Controls

No compensating control documented

23 Expiring Soon

Expiry within 14 days

19 Orphaned Owner

Owner is inactive or unassigned

GRC Intelligence Center

186 Total GRC Findings

Detected across 600 exceptions

27 Critical Accumulation

Assets with stacked risk ≥ 1500

90 Overlapping Exceptions

Same asset + policy, concurrent dates

59 Duplicate Waivers

Same dept + asset + type, similar justification

0 Conflicting Approvals

No governance conflicts detected

37 Risk Hotspots

Assets accumulating high combined risk

Compliance Frameworks

NIST AC-2

Account Management — exception lifecycle & access control tracking

NIST PL-4

Rules of Behavior — policy waiver governance and documentation

GDPR Article 25

Data Protection by Design — privacy risk captured in exception intake

CIS Control 1.1

Inventory of Assets — asset-mapped exception registry

ISO 27001 A.9

Access Control — enforces review, expiry, and approval workflows

CIA Impact Classification

C

Confidentiality

Data disclosure risk if exception is misused

I

Integrity

Data accuracy at risk from unauthorized changes

A

Availability

Service disruption risk if exception expires

M

Multiple

Exceptions impacting more than one CIA dimension

1 Home Page

Marketing + role cards

2 Login

Demo role selection

3 Dashboard

GRC Command Center

4 Risk Register

600 exceptions, filter & search

5 Intake Form

Structured exception request

6 Review Queue

Security reviewer workflow

7 Evidence File

Exception detail & history

8 Risk Scoring

Score explainer & bands

9 Alerts

682 active alerts dashboard

10 GRC Intelligence

186 findings, hotspots

11 Audit Report

Department & lifecycle breakdown

12 Settings

Config, roadmap, dataset stats

GRC Command Center

Continuous monitoring of policy exceptions, risk exposure, lifecycle status, and audit readiness.

DASHBOARD VIEW

Executive Overview

Workspace: Security Reviewer

Live Demo Environment

34

Exception Health Score
out of 100 - overall posture

602

Total Exceptions
tracked policy exceptions

427

Critical Risks
highest severity exposures

162

Overdue Reviews
past their review date

24

Expiring Soon
expire within 14 days

19

Orphaned Exceptions
no active owner

Exception Posture Summary

The portfolio holds 602 tracked exceptions — 555 at High/Critical risk, 157 overdue, and 19 orphaned. Average risk is 87/100. Overall posture: **At Risk**.

RISK EXPOSURE

555

High/Critical exceptions - 427 critical

AUDIT READINESS

Gaps Found

157 overdue - 19 orphaned

LIFECYCLE HEALTH

358/602

active - 134 pending review

WORKSPACE ACTIONS

Open Review Queue

View Risk Scoring

View Alerts

AUDITOR:ADMIN
ACTIVE WORKSPACE

Dashboard

Exception Registry

Risk Scoring

Alerts

GRC Intelligence

Audit Report

Settings

Login

RISK INTELLIGENCE - CRITICAL
HOTSPOTS
EXCEPTION ACCUMULATION - ASSET
TRENDS

All Findings (186)

77 critical, 109 high, overall

Search asset, exception ID, reason...

All Severities

All Types

8 Cards Table

RISK ACCUMULATION Critical

Risk Accumulation - Customer Onboarding Portal

47 active exceptions on asset "Customer Onboarding Portal" accumulate to a combined risk of 3861 (avg 82) — a hidden hotspot.

ASSET / SYSTEM

Customer Onboarding Portal

RELATED

47 exception(s)

EXCM0030 EXCM0036 EXCM0067 EXCM0080 EXCM0082 EXCM0100

EXCM0110 EXCM0123 EXCM0130 EXCM0144 EXCM0165 EXCM0175

EXCM0182 EXCM0204 EXCM0207 EXCM0230 EXCM0237 EXCM0252

EXCM0258 EXCM0279 EXCM0285 EXCM0293 EXCM0301 EXCM0325

EXCM0337 EXCM0346 EXCM0360 EXCM0361 EXCM0374 EXCM0379

RISK ACCUMULATION Critical

Risk Accumulation - SIEM Platform

40 active exceptions on asset "SIEM Platform" accumulate to a combined risk of 3674 (avg 92) — a hidden hotspot.

ASSET / SYSTEM

SIEM Platform

RELATED

40 exception(s)

EXCM0015 EXCM0027 EXCM0037 EXCM0050 EXCM0063 EXCM0095

EXCM0081 EXCM0089 EXCM0137 EXCM0149 EXCM0170 EXCM0171

EXCM0083 EXCM0200 EXCM0220 EXCM0230 EXCM0241 EXCM0265

EXCM0269 EXCM0291 EXCM0300 EXCM0304 EXCM0314 EXCM0327

EXCM0330 EXCM0373 EXCM0419 EXCM0440 EXCM0453 EXCM0475

Current Prototype

- localStorage-based demo authentication (no session security)
- JSON flat-file storage (not production-grade)
- No backend RBAC — roles enforced frontend only
- Email notifications are simulated (not sent)
- PDF export via browser print (not server-generated)
- Captcha is frontend-only, no CSRF protection
- 30 demo system users only (not a real user directory)

Production Roadmap

- SSO / OIDC integration (Okta, Azure AD)
- Backend RBAC with JWT-secured routes
- PostgreSQL or MongoDB for data persistence
- ServiceNow / Jira / CMDB integration
- IAM / Active Directory owner resolution
- Real PDF audit report generation
- AI-assisted risk scoring (future scope only)

"RiskWaiver360 turns scattered exceptions into centralized, risk-scored, lifecycle-tracked, audit-ready governance decisions."